

An Overview of Container Security in a Kubernetes Cluster

Kazenas German

*Institute of Radioelectronics and
Information Technology
Ural Federal University
Yekaterinburg, Russia
German.Kazenas@urfu.me*

Olga Ponomareva

*Institute of Radioelectronics and
Information Technology
Ural Federal University
Yekaterinburg, Russia
o.a.ponomareva@urfu.ru*

Abstract—Recently, the use of container technology for applications has become commonplace. The advantages of this technology allow you to quickly develop and implement new services and applications in any programming language. The Kubernetes platform is the most popular container orchestration tool and is widely used for application development and deployment. Kubernetes not only allows you to deploy applications, but also performs functions such as load balancing, storage organization, secret storage and much more. However, experts pay attention to possible security problems when using Kubernetes. Attackers can use application containers in Kubernetes not only to obtain data processed by the application, but also to form an entry point into the company's infrastructure for a subsequent attack on the company's internal assets. The configuration requirements of the containerization platform cannot fully protect against malicious actions from containers, so it is necessary to supplement the protection system with tools that could track actions in the container in real time. This article will compare several Kubernetes real-time cluster security solutions and show their advantages and disadvantages.

Keywords—Kubernetes, security, Falco, Aqua security, NeuVector, Sysdig Secure

I. INTRODUCTION

Kubernetes is now becoming increasingly popular around the world, and its ecosystem is growing rapidly. Kubernetes (K8s) is an open source software for automating the deployment, scaling and management of containerized applications [1]. Available studies such as [2, 3, 4, 5] disclose the requirements that must be met to improve the security of applications in a K8s cluster. However, they do not cover the issues of real-time application security monitoring in containers, which confirms the relevance of this study.

The purpose of this paper is to review K8s security monitoring tools both in terms of required security requirements and real-time monitoring of application containers within K8s.

Consider the available K8s security platforms, the functionality of which allows you to control containerized applications in real time and which can be installed in your own enterprise infrastructure.

II. AQUA CONTAINER SECURITY PLATFORM

The developers of the Aqua Container Security Platform note that the platform provides a full cloud application security cycle that includes containers, container orchestrators, virtual machines and iron machines. Aqua uses policy-based controls to ensure security, including when using

the CI/CD pipeline. Application security within K8s is also implemented using enforcers. They protect applications at runtime and detect and block attacks that are initiated from the application container. The Aqua Container Security Platform provides functionality to both perform audits of the security settings of the containerized environment and manage security risks [6].

Aqua Container Security Platform uses a different number of levels, each of which can apply certain policies.

Aqua Container Security Platform can be deployed locally or in a public cloud environment. The components of the platform are containerized and easy to deploy, such as with Helm.

One of the great benefits of Aqua Container Security Platform is the dynamic scanning of containers for malicious activity while the container is running. To manage risk, it is possible to issue special rules for a specific vulnerability in the image on which the container is running, in automatic mode to reduce the likelihood of exploitation.

Aqua Container Security Platform follows global best practices and uses CIS Benchmark. Aquasecurity has developed its own open-source tool for CIS kube-bench checks.

Additionally Aqua Container Security Platform supports DISA STIG Benchmarks, NIST, HIPAA.

III. NEUVECTOR

NeuVector is a containerized security platform. This solution enables security by scanning for vulnerabilities in images and the containerization platform, filtering packets of container network communication at layer 7.

NeuVector can be deployed locally or in cloud K8s clusters. The platform components are containerized and easy to deploy, for example, using Helm or ready-made deployment manifests.

NeuVector embeds itself in CI/CD pipelines to scan vulnerabilities from build to delivery and launch. Policies can be used to limit or prevent deployment of vulnerable images. Containers, K8s, and hosts are also scanned at runtime.

NeuVector's operating logic is implemented through agents on each host - Enforcer. It implements all the security and control functions. NeuVector is managed through the graphical interface of the controller, but REST APIs or command line interfaces are also supported.

NeuVector follows global best practices and uses the CIS Benchmark: auditing host and container security with the Docker Bench and Kubernetes CIS Benchmark.

NeuVector automatically creates a container profile based on its network and software behavior. This allows for a zero-trust approach in which only what is normal application operation is allowed. This approach allows you to resist zero-day attacks.

One of the interesting features of NeuVector is the ability to dump the network traffic of an individual container and save it in pcap format. This allows you to both fix errors in applications and collect digital evidence, which can help in the investigation of information security incidents.

A feature of this tool is DLP, which prevents sensitive information from leaking outward.

IV. SYSDIG SECURE

Sysdig Secure is part of the Sysdig container analytics platform. The platform components are containerized. Sysdig uses a unified platform for cloud and container security, monitoring and forensics that maps information with a bias toward microservices architecture. In doing so, the system is fully integrated with Docker and Kubernetes [8].

Sysdig Secure, like the previously presented products, has features for scanning images of containers and nodes in a containerized environment.

Sysdig Secure for real-time protection of application containers allows detecting and remembering user actions both within the protection system and in the container, container activity in terms of network interaction, and command line arguments for processes running within the container.

Sysdig Secure makes active use of security policies, which together with application and container monitoring allows you to identify and block threats in real time.

Sysdig Secure uses not only CIS Benchmark, NIST, HIPAA, but also Kubernetes' own security experience.

The big advantage of Sysdig Secure is the investigation functionality. The solution allows you to conduct investigations based on the results of policy violations, activity data, user activity tracing data both in shells and using kubectl commands.

V. PRISMA CLOUD

The Twistlock platform is part of the Prisma Cloud and provides full container lifecycle security [9].

This tool has the functionality of scanning and monitoring container registries, scanning images and viewing scan reports, creating and applying infrastructure and container compliance rules.

This solution also has a layer 7 firewall, which allows you not only to monitor the network activity of containers, filter packets and impose network restrictions, but also to discover container application API endpoints. Defining an API allows the solution to scan them and provide flaw or error reports, which is a big advantage over the competition.

The tool also has the ability to run on a company's local infrastructure sandbox to run and parse container images. An

important difference from the similar functionality of Aqua is the location in the local network of the company.

A specialized data logger is built into the solution, which works together with all containers in the environment and is necessary to collect information for further enrichment with data for a full and fast investigation of incidents.

VI. FALCO

The Falco project [10] is an open source project for real-time security. Falco was introduced by Sysdig. The basis of Falco's work is to intercept Linux system calls. Falco has the functionality to collect events from multiple locations, including K8s, for a full real-time view of the situation. Falco can also be extended to other data sources via plugins. Falco has worked with the community to develop rules for different levels of application operation: host, Kubernetes, container.

The rules for detecting system calls are presented in YAML syntax. Each condition you write for these events usually starts with an expression or macro. One aspect of this approach is that security rules usually consider one type of system call at a time.

The first big disadvantage of Falco is the inability to prevent malicious actions or attacks. The second disadvantage is the lack of functionality to control the security related parameters of K8s and the containers in them. The next major disadvantage is the lack of a graphical interface, the results can be collected in a text file or sent to various logging solutions.

But the lack of a graphical interface is offset by a large number of information output formats. These include output to a text file, output to a JSON text file, syslog, output as a program launch parameter, HTTP/HTTPS, and gRPC. For the latter inference, several clients have been developed by the community in the Python and Go programming languages.

VII. TOOL COMPARISON

The solutions that were presented have very similar functionality, which can be misleading and confusing when choosing. Let's compare aspects of different applications and show possible use cases for each. Fig. 1 presents a comparison according to some criteria.

Solution	Free	GUI	API	Compliance	Vulnerability scan	Runtime detection	Runtime protection	External control
Prisma Cloud	No	Yes	Yes	Yes	Yes	Yes	Yes	Yes
Aqua	No	Yes	Yes	Yes	Yes	Yes	Yes	No
NeuVector	Yes	Yes	Yes	Yes	Yes	Yes	Yes	No
Sysdig Secure	No	Yes	Yes	Yes	Yes	Yes	Yes	No
Falco	Yes	No	Yes	No	No	Yes	No	Yes

Fig. 1. Tool Comparison.

The Free criterion indicates whether the solution is free to use or commercial. The GUI and API criteria provide information about whether the tool has a graphical or programmatic interface, respectively. The Compliance criterion shows the availability of functions for checking the configurations of elements of a containerized environment. Vulnerability scan is required to show the capabilities of scanning images, the platform for vulnerabilities and work with these vulnerabilities. Runtime detection and protection indicate whether a solution can detect attacks in real time and prevent them, respectively. External control provides information about the ability of the solution to control

containerized applications outside of the containerization platform.

Based on this table, it can be seen that for security teams with a large budget, it is recommended to use the Container Security Platform and Sysdig Secure. But teams with lower budgets can also count on K8s to protect their applications when using NeuVector. Falco, based on the table, is used as a niche solution for detecting malicious influence from a containerized environment both inside and outside of it.

VIII. CONCLUSION

Thus, as a result of this study, brief descriptions of K8s security tools and applications in them are given. One important aspect is that even open source tools such as NeuVector can provide functionality very similar to Aqua and Sysdig commercial solutions.

Aqua, Sysdig, NeuVector solutions allow you to monitor both K8s security requirements and application containers in real time.

But if the K8s security requirements are met and controlled in any other convenient way, then real-time container and application control can be implemented using Falco. This will greatly expand the scope and control to a containerized environment.

This article does not provide a detailed analysis of the functionality of each solution, since this is the topic of a separate article and a separate study.

REFERENCES

- [1] Kubernetes official website, Feb. 2023. [Online]. Available: <https://kubernetes.io/ru/>
- [2] A. A. Zhilina, "Security of a virtual infrastructure built on the basis of a microservice architecture using the KUBERNETES orchestrator," presented at the Collection of articles based on materials from the V International Scientific-practical conference, Moscow, Apr. 14, 2022.
- [3] A. A. Zhilina, S. M. Volodin, "Information security: yesterday, today, tomorrow," presented at the Collection of articles based on materials from the V International Scientific-practical conference, Moscow, Apr. 14, 2022, pp. 66-72.
- [4] S. E. Lipatova, Yu. S. Belov, "Cybersecurity practices in Kubernetes," presented at the E-Scio, 2022, No. 1 (64), S. 489-497.
- [5] M.S. Islam Shamim, F. Ahamed Bhuiyan, A. Rahman, "XI Commandments of Kubernetes Security: A Systematization of Knowledge Related to Kubernetes Security Practices," presented at the IEEE Secure Development (SecDev), Atlanta, GA, USA, 2020, pp. 58-64.
- [6] F. Minna, A. Blaise, F. Rebecchi, B. Chandrasekaran, F. Massacci, "Understanding the Security Implications of Kubernetes Networking," presented at the IEEE Security & Privacy, Sept.-Oct. 2021, vol. 19, no. 5, pp. 46-56.
- [7] Aqua Container Security Platform Overview, Feb. 2023. [Online]. Available: <https://www.aquasec.com/aqua-cloud-native-security-platform/>
- [8] NeuVector Docs, Feb. 2023. [Online]. Available: <https://open-docs.neuvector.com/>
- [9] Documentation of Sysdig Secure, Feb. 2023. [Online]. Available: <https://docs.sysdig.com/en/docs/sysdig-secure/>
- [10] Documentation of Prisma Cloud, Feb. 2023. [Online]. Available: <https://docs.paloaltonetworks.com/prisma/prisma-cloud>
- [11] Falco Documentation, Feb. 2023. [Online]. Available: <https://falco.org/docs/>